

SIEM and SOAR architecture

Key Terms:

Orchestration. Orchestration means combining human expertise with automation. Humans guide the response, while automated tools handle repetitive tasks. It's faster than manual work but flexible enough to handle the unknown.

Automation: This involves taking the repetitive, manual tasks that human analysts usually do and letting the machine handle them.

False Positive: A "false alarm" when a tool thinks something is a virus, but it's actually a safe file.

Enrichment: Adding extra context to an alert (e.g., seeing not just an IP address, but who owns it and where it's located).

The Playbook (The Script): A Playbook is a pre-defined set of steps for a specific type of threat. For Example: If a "Phishing Email" is reported, the Playbook might say: 1. Scan the link, 2. Check the sender's reputation, 3. If malicious, delete the email and block the sender.

SIEM(Security information and event management):

SIEM is software that helps organizations detect, analyze, and respond to security threats by collecting and correlating security event data from across the IT environment in real time(1).

In simple terms SIEM is a centralized security system (central "brain") that collects data("logs") from across your entire company, organizes them, and alerts you if it sees something suspicious. It doesn't usually "do" anything to stop a hacker; its job is to notice that something is wrong by connecting the dots. It checks

"Is something suspicious happening right now?"

Components of SIEM

1. Data Collection and Aggregation

SIEM gathers security data from devices, servers, apps, and networks. It combines logs in real-time to capture all possible security events.

2. Normalization and Parsing

Since data comes in different formats, SIEM standardizes (normalizes) it and breaks it down (parsing) into clear elements for easier analysis.

3. Correlation Engine

This is the core of SIEM. It detects threats by finding patterns, unusual behavior, or matching events with known threats using rules, machine learning, and threat intelligence.

4. Alerting and Reporting

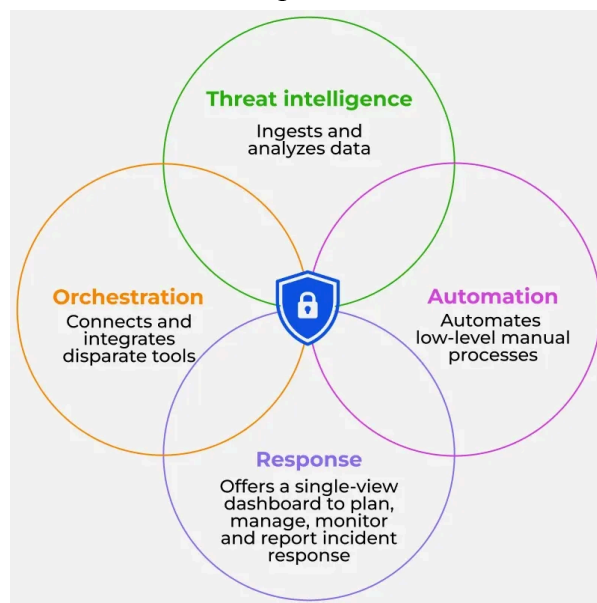
When suspicious activity is found, SIEM sends alerts to security teams for quick action. It also provides detailed reports and dashboards to track trends and compliance.

5. Log Management and Retention

SIEM securely stores logs for audits and investigations. Retention policies depend on industry rules (e.g., healthcare requires logs for six years).

SOAR(Soar stands for Security Orchestration, Automation, and Response):

SOAR, for security orchestration, automation and response, is a software solution that enables security teams to integrate and coordinate separate security tools, automate repetitive tasks and streamline incident and threat response workflows



SOAR Architecture

1. The Ingestion Layer (The Inputs)

This is the entry point. The architecture must be able to "swallow" data from multiple sources.

- **SIEM/XDR Feeds:** High-priority alerts about potential breaches.
- **Application Logs:** Direct logs from critical software (e.g., login failures, database errors).
- **Email Gateways:** Reports of phishing or malicious attachments.
- **Threat Intel:** Feeds from outside the company that list known "bad" IP addresses and viruses.

2. The Integration Layer (The Connectors)

This is the most critical technical part of the architecture. SOAR uses **APIs (Application Programming Interfaces)** to talk to other tools.

- Instead of a human logging into a Firewall to block an IP, the SOAR architecture uses a **Connector** to send a digital command directly to the Firewall's "brain."

- This layer "normalizes" data, meaning it takes different log formats and turns them into a single, readable language.

3. The Orchestration & Automation Engine (The Brain)

This is where the logic happens. It consists of two main components:

- **Playbooks:** These are the "if-then" workflows. The engine reads the playbook and decides which tool to trigger next.
- **Decision Logic:** This determines if an action should be **Fully Automated** (done by the machine) or **Semi-Automated** (the machine prepares the work, but waits for a human to click "Approve").

4. The Case Management & Presentation Layer (The Interface)

This is what the human security analyst sees.

- **Dashboards:** Visual charts showing how many attacks were stopped today.
- **Timeline:** A digital record of every step the SOAR took (e.g., "12:01: Alert Received; 12:01: IP Blocked; 12:02: Email Deleted").
- **Alert Categorization:** It groups 100 related logs into one single "Case" so the analyst isn't overwhelmed.

SOAR vs. SIEM

In the world of cybersecurity, both SOAR and SIEM are integral in protecting organisations from cyber threats. However, understanding the distinctions between SOAR and SIEM is essential in selecting an appropriate solution for your organisation.

Security, Orchestration, Automation, and Response (SOAR)

- **Automation:** A key feature of SOAR solutions, automation enables security teams to streamline repetitive tasks by automatically executing predefined actions or workflows based on specific triggers or conditions.
- **Orchestration:** This involves coordinating various security tools and technologies within an organisation's infrastructure to improve threat detection, investigation, and response capabilities.
- **Response:** SOAR platforms provide a centralised interface for managing incident responses across multiple security tools while also enabling collaboration among team members during investigations.

Security Information and Event Management (SIEM):

- **Data Collection & Aggregation:** SIEM systems collect data from various sources such as network devices, servers, applications, databases, etc., providing a comprehensive view of an organisation's IT environment.
- **Data Analysis & Correlation:** SIEM solutions analyse collected data in real-time using correlation rules that identify patterns indicative of potential threats or malicious activities. This helps detect incidents early on before they escalate into more significant issues.
- **Reporting & Compliance:** One primary function of SIEMs is generating reports required for regulatory compliance monitoring and reporting.

Scenario: Phishing Email Attack

- **Detection:** An employee clicks a suspicious link in an email. The **Application Logs** from the email gateway detect the click and send an alert to the SIEM.
- **Trigger:** The SIEM recognizes the link as a known malicious URL and automatically pushes the alert to the **SOAR** platform.
- **Automated Investigation:** The SOAR instantly extracts the URL and the user's email address. It "queries" a threat intelligence database to confirm the site is a credential-stealing page.
- **Orchestration in Action:** The SOAR reaches out to the **Email Server** and searches for that same email in every other employee's inbox.
- **Automated Response:** The SOAR **deletes** the malicious email from all 500 employee inboxes simultaneously to prevent further clicks.
- **Containment:** The SOAR automatically triggers a **forced password reset** for the specific employee who clicked the link and isolates their laptop from the network.

How Logs Move Through the System

In a SOAR-integrated environment, logs follow a specific path. We will use **Application Logs** (like a web store login) as our example:

- **Step 1: The Source (Application Layer)** The application generates a "Raw Log."
- **Step 2: The Collector (SIEM Layer)** The log is sent to the **SIEM**. The SIEM's job is to index this log so it can be searched. It looks at thousands of these logs. If it sees 100 "Failed" statuses for the "Admin" user in 30 seconds, it realizes this is a **Brute Force Attack**.

- **Step 3: The Handoff (The API Bridge)** The SIEM "bundles" these related logs into a **Security Alert**. It sends this alert to SOAR via an API. The log has now officially moved from a "record of history" to an "active investigation."
- **Step 4: The Case (SOAR Layer)** The SOAR takes the log data and puts it into a **Case Folder**. It pulls out specific "Artifacts" (the IP address, the Username, the Time) and displays them on the analyst's dashboard.

2. Where Automation Happens

A. Investigative Automation (Enrichment)

This happens the **moment** the log hits the SOAR. Before a human even knows there is an alert, the SOAR begins "Enrichment."

- **The Action:** The SOAR automatically takes the IP address from the log and asks a Threat Intelligence database: *"Is this IP a known hacker?"*
- **The Benefit:** It saves the analyst 10 minutes of manual searching.

B. Decision Logic Automation (The Playbook)

This happens in the **Middle** of the process. The SOAR runs a "Playbook" to decide what to do.

- **The Action:** If the IP is from a "High Risk" country AND the user is a "VIP" (like the CEO), the automation path switches to "Critical Response." If it's a low-level employee on a known office IP, it might just send a warning email.
- **The Benefit:** It ensures the most dangerous threats are prioritized without human sorting.

C. Remediation Automation (The Response)

This happens at the **End** of the process.

- **The Action:** Once the threat is confirmed, the SOAR sends an automated command to the **Firewall** to block the IP and to the **Active Directory** to disable the user's account.
- **The Benefit:** The threat is stopped in seconds. If you waited for a human to log into the firewall and manually type in the block command, the hacker might have already stolen the data.